

Индивидуальный проект

5 Этап. Использование Burp Suite

Панина Жанна Валерьевна

Содержание

1	Цель работы	4
2	Теоретическое введение	5
3	Выполнение работы	6
4	Выводы	17
	Список литературы	18

Список иллюстраций

3.1	Запуск mysql и apache2	6
3.2	Запуск Burp Suite	6
3.3	Сетевые настройки браузера	7
3.4	Изменение настроек	7
3.5	Изменение настроек Proxy	8
3.6	Включение Intercept	8
3.7	Параметр network_allow_hijacking_localhost	8
3.8	Захваченный запрос	9
3.9	Страница авторизации и изменения	9
3.10	Вкладка Target	9
3.11	Попытка входа	10
3.12	Вкладка Target	10
3.13	Вкладка Intruder	11
3.14	Изменение типа атаки	11
3.15	Первый список со значениями	12
3.16	Второй список со значениями	12
3.17	Запуск атаки	13
3.18	Результаты подбора	13
3.19	Правильно подобранная пара	14
3.20	Проверка через Repeater	14
3.21	Вкладка Repeater	15
3.22	Просмотр Response	15
3.23	html код	16
3.24	Как выглядит полученная страница в Render	16

1 Цель работы

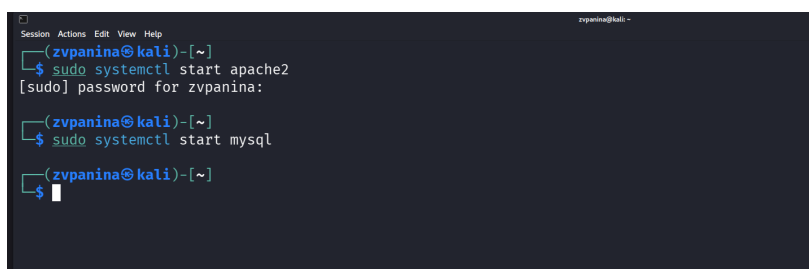
Научиться использовать инструмент Burp Suite.

2 Теоретическое введение

Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения. Эти инструменты позволяют сканировать, анализировать и использовать веб-приложения с помощью ручных и автоматических методов. Интеграция интерфейсов этих инструментов обеспечивает полную платформу атаки для обмена информацией между одним или несколькими инструментами, что делает Burp Suite очень эффективной и простой в использовании платформой для атаки веб-приложений.

3 Выполнение работы

Запускаю локальный сервер для дальнейшего тестирования Burp Suite (рис. 3.1).



```
zvpanina@kali ~  
$ sudo systemctl start apache2  
[sudo] password for zvpanina:  
zvpanina@kali ~  
$ sudo systemctl start mysql  
zvpanina@kali ~  
$
```

Рисунок 3.1: Запуск mysql и apache2

Запускаю инструмент Burp Suite (рис. 3.2).

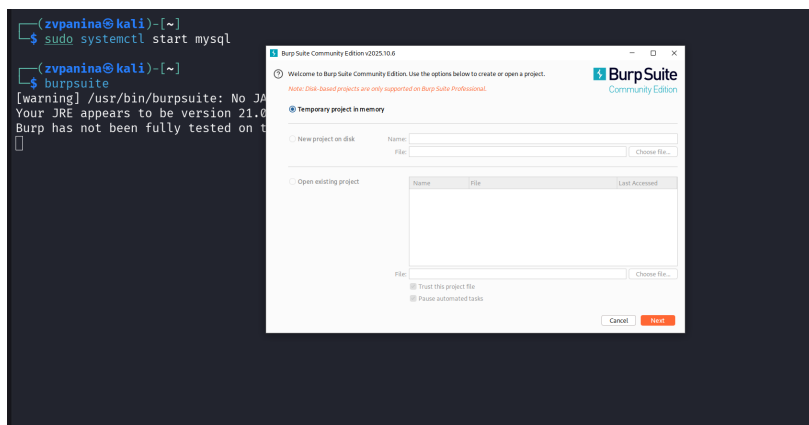


Рисунок 3.2: Запуск Burp Suite

Открываю сетевые настройки браузера для подготовки к работе (рис. 3.3).

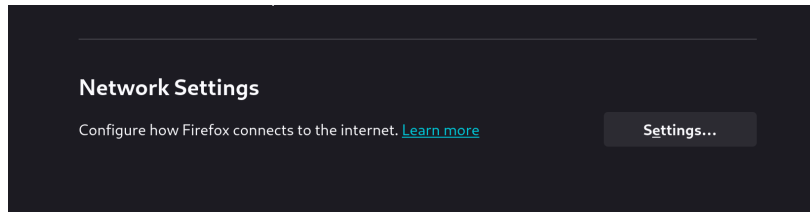


Рисунок 3.3: Сетевые настройки браузера

Изменяю настройки сервера для работы с прокси и захвата данных с помощью Burp Suite (рис. 3.4).

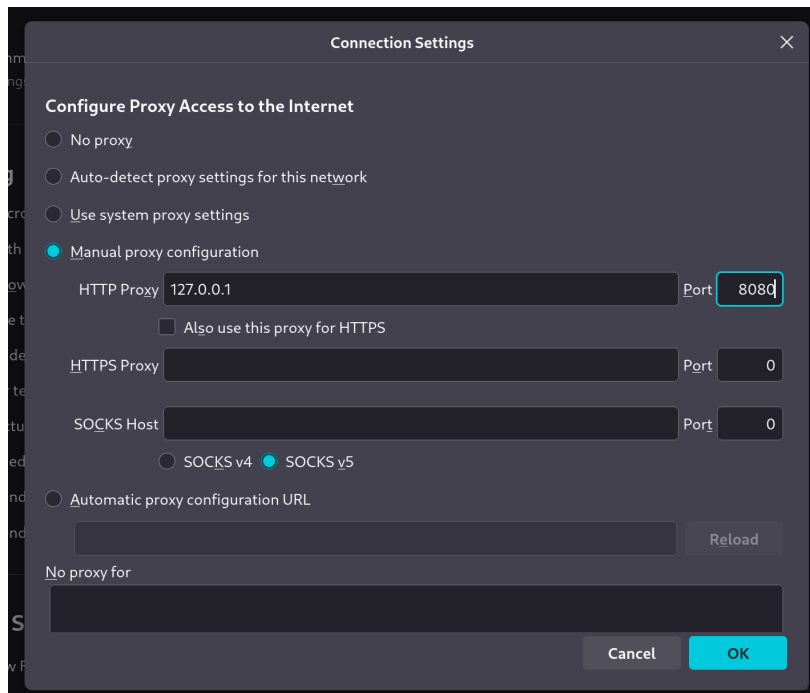


Рисунок 3.4: Изменение настроек

Изменяю настройки Proxu в Burp Suite для дальнейшей работы (рис. 3.5).

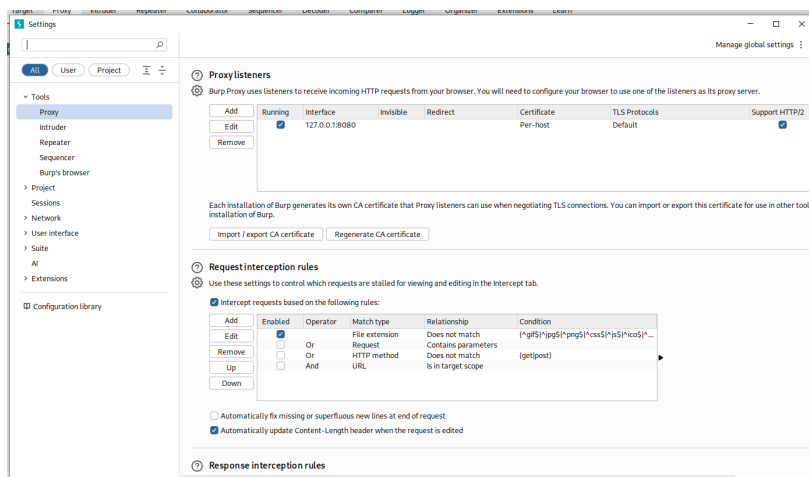


Рисунок 3.5: Изменение настроек Proxy

Во вкладке Proxy устанавливаю значение «Intercept» на «on» (рис. 3.6).

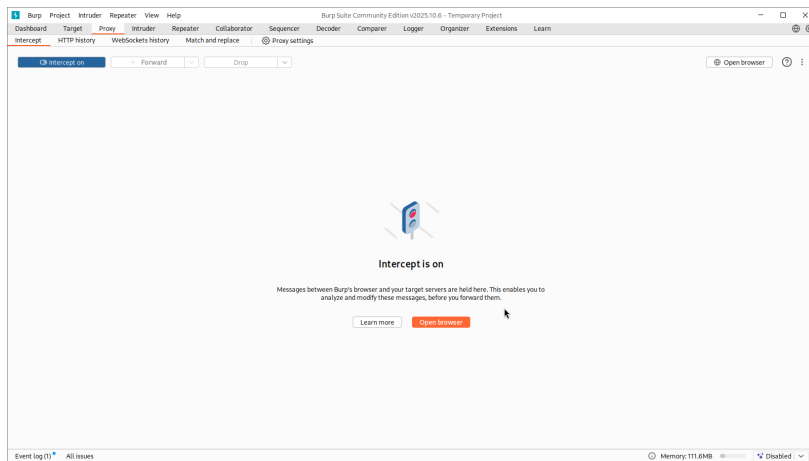


Рисунок 3.6: Включение Intercept

Устанавливаю параметр `network_allow_hijacking_localhost` на `true`, чтобы Burp Suite корректно работал с локальным сервером (рис. 3.7).

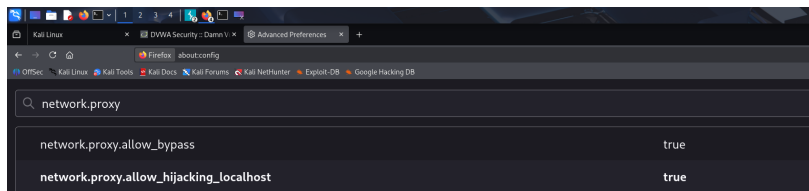


Рисунок 3.7: Параметр `network_allow_hijacking_localhost`

Пытаюсь зайти в браузер на DVWA, сразу во вкладке Proxu вижу захваченный запрос. Нажимаю «Forward» для загрузки страницы (рис. 3.8).

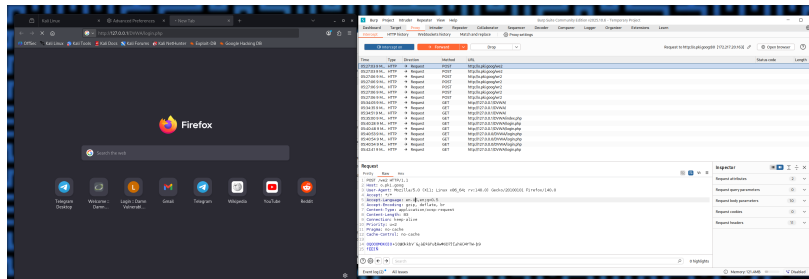


Рисунок 3.8: Захваченный запрос

Сразу загрузилась страница авторизации и поменялся текст запроса (рис. 3.9).

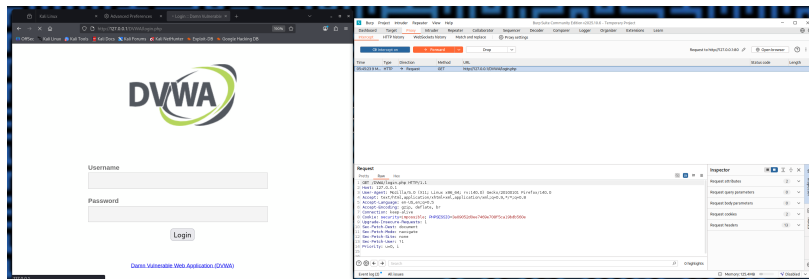


Рисунок 3.9: Страница авторизации и изменения

Можем перейти на вкладку Target, чтобы посмотреть историю запросов (рис. 3.10).

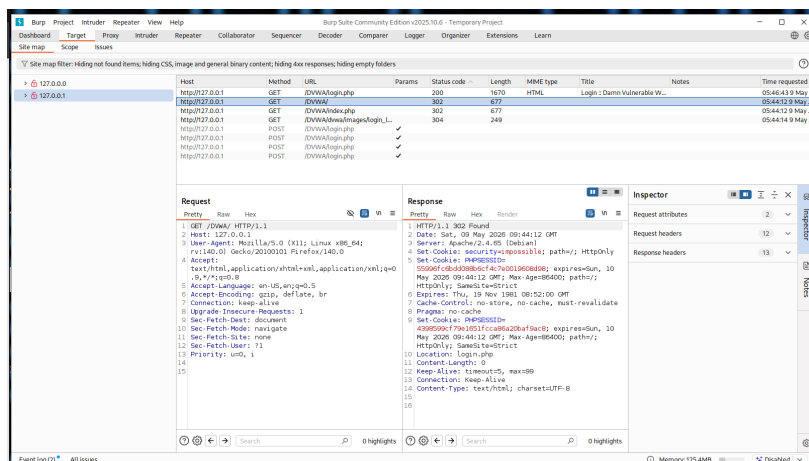


Рисунок 3.10: Вкладка Target

Ввожу неверные случайные данные для входа, пытаюсь залогиниться и вижу в запросе строку, в которой отображаются введенные мной данные (рис. 3.11).

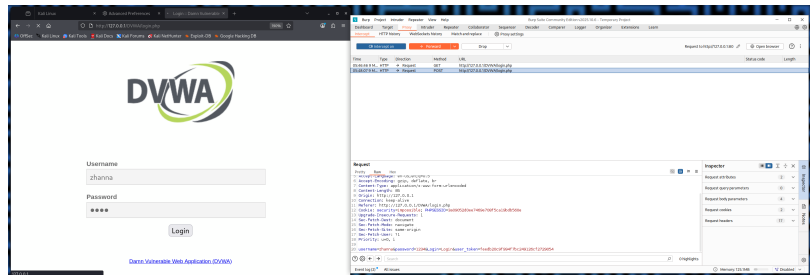


Рисунок 3.11: Попытка входа

Этот запрос можем также найти во вкладке Target, нажав правой кнопкой мыши на хост нужного запроса и далее «Send to Intruder» (рис. 3.12).

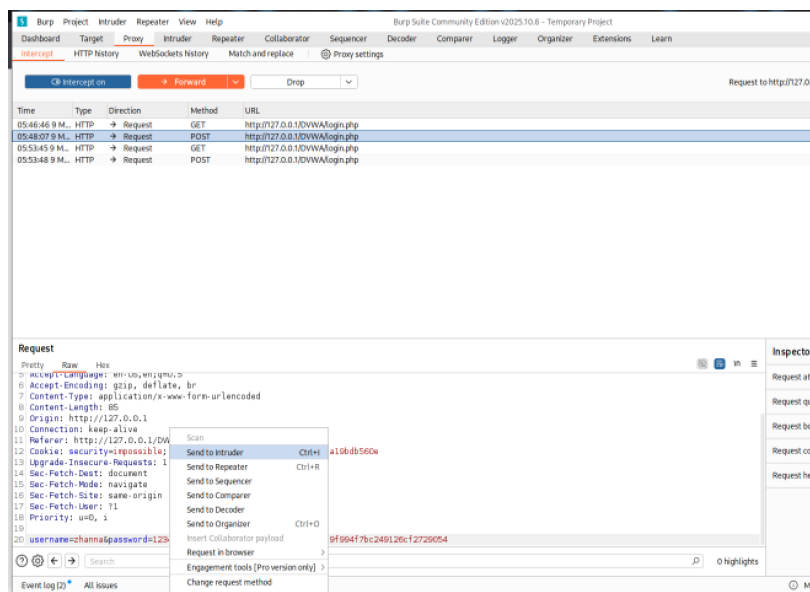


Рисунок 3.12: Вкладка Target

Переходим на вкладку Intruder, видим свой запрос и значение по умолчанию у типа атаки (рис. 3.13).

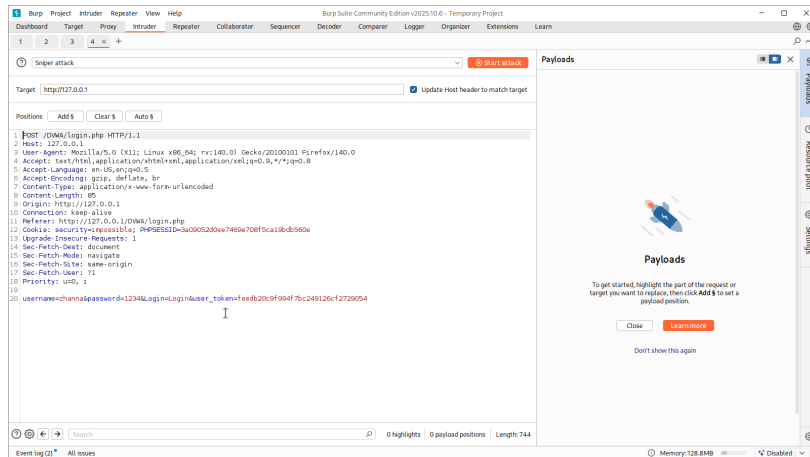


Рисунок 3.13: Вкладка Intruder

Изменяем значение типа атаки на Cluster Bomb attack и проставляем специальные символы у имени пользователя и пароля - эти данные и будем пробивать (рис. 3.14).

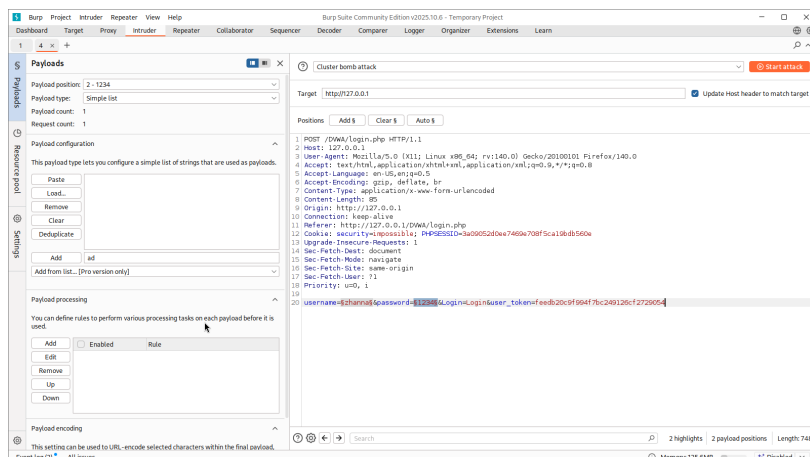


Рисунок 3.14: Изменение типа атаки

Составляем два списка со значениями для подбора в Payload setting - сначала первый (рис. 3.15).

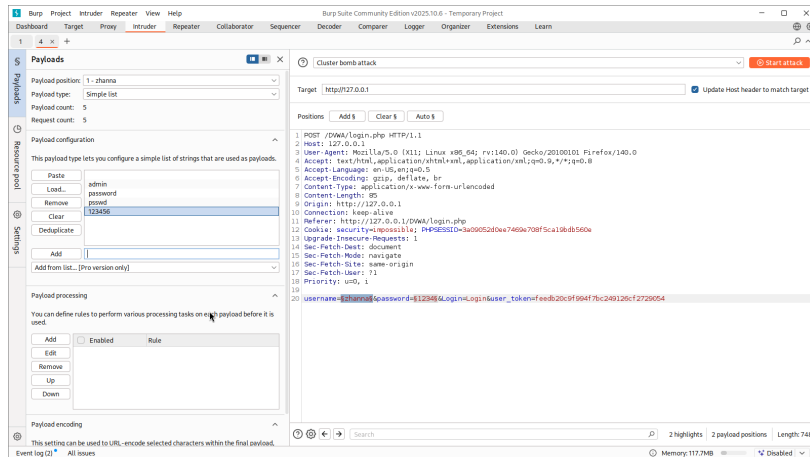


Рисунок 3.15: Первый список со значениями

Затем второй (рис. 3.16). В строке Request count видим число - это нужное количество запросов, чтобы проверить все возможные пары пользователь-пароль.

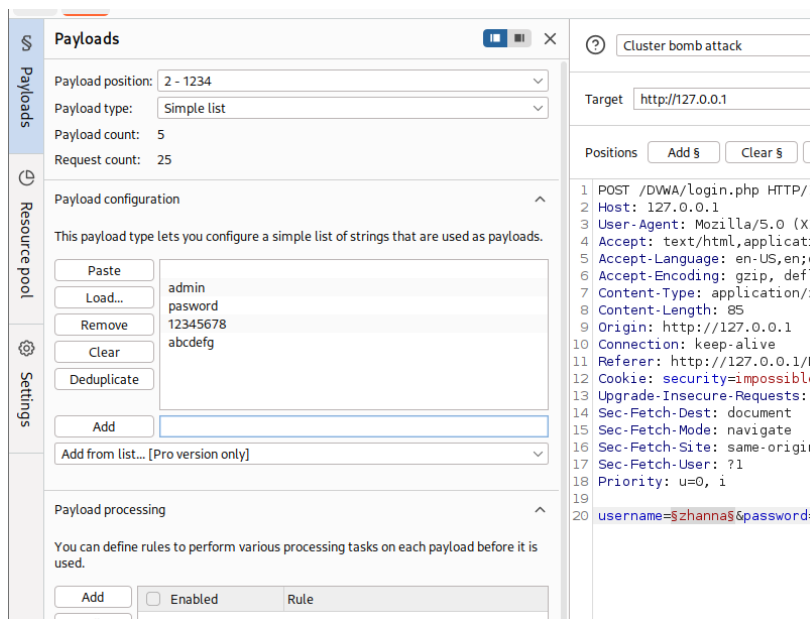


Рисунок 3.16: Второй список со значениями

Нажимаю start attack, и начинается подбор (рис. 3.17).

Request	Response	Status code	Response received	Error	Timeout	Length	Comment
1	admin	200	200			481	
2	password	200	200			481	
3	admin	200	200			481	
4	password	200	200			481	
5	admin	200	200			481	
6	password	200	200			481	
7	admin	200	200			481	
8	password	200	200			481	
9	admin	200	200			481	
10	password	200	200			481	
11	admin	200	200			481	
12	password	200	200			481	
13	admin	200	200			481	
14	password	200	200			481	
15	admin	200	200			481	
16	password	200	200			481	
17	admin	200	200			481	
18	password	200	200			481	
19	admin	200	200			481	
20	password	200	200			481	
21	admin	200	200			481	
22	password	200	200			481	
23	admin	200	200			481	
24	password	200	200			481	
25	admin	200	200			481	

Рисунок 3.17: Запуск атаки

При открытии результата каждого post-запроса можем увидеть полученный get-запрос: по нему видно, куда нас перенаправило после выполнения ввода пары пользователь-пароль. Например, в случае с подбором пары password-abcdefg нас перенаправило на login.php, это значит, что пара не подходит (рис. 3.18).

Request	Response	Status code	Response received	Error	Timeout	Length	Comment
1	admin	200	200			481	
2	password	200	200			481	
3	admin	200	200			481	
4	password	200	200			481	
5	admin	200	200			481	
6	password	200	200			481	
7	admin	200	200			481	
8	password	200	200			481	
9	admin	200	200			481	
10	password	200	200			481	
11	admin	200	200			481	
12	password	200	200			481	
13	admin	200	200			481	
14	password	200	200			481	
15	admin	200	200			481	
16	password	200	200			481	
17	admin	200	200			481	
18	password	200	200			481	
19	admin	200	200			481	
20	password	200	200			481	
21	admin	200	200			481	
22	password	200	200			481	
23	admin	200	200			481	
24	password	200	200			481	
25	admin	200	200			481	

Рисунок 3.18: Результаты подбора

Проверяем результат пары admin-password во вкладке Response; здесь нас перенаправило на страницу index.php, значит, эта пара верна (рис. 3.19).

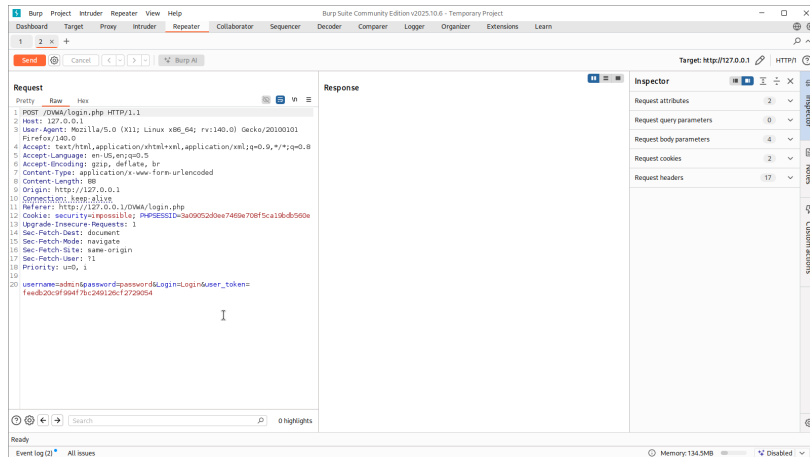


Рисунок 3.21: Вкладка Repeater

Нажав кнопку «send», получаю в «Response» в строке Location перенаправление на index.php (рис. 3.22).

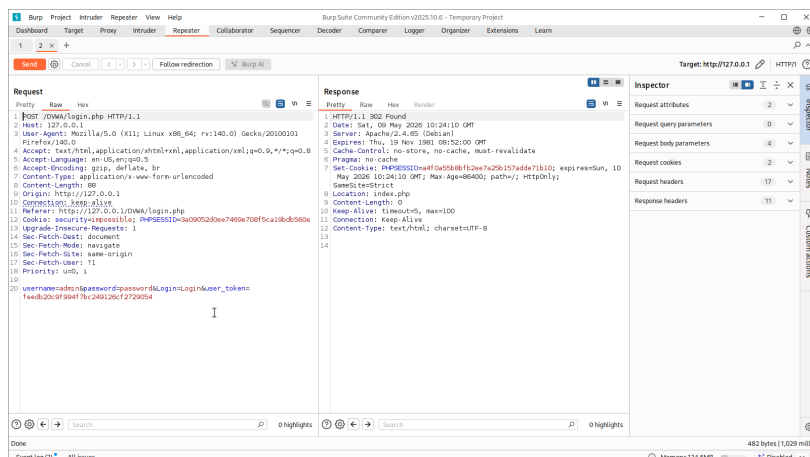


Рисунок 3.22: Просмотр Response

Нажав на Follow redirection, получаю нескompiliroанный html-код в окне Response (рис. 3.23).

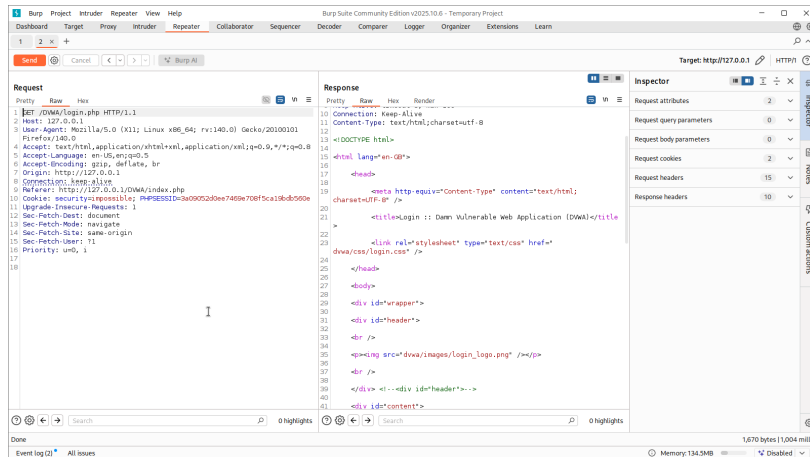


Рисунок 3.23: html код

Захожу в окно Render и вижу изображение полученной страницы (рис. 3.24).

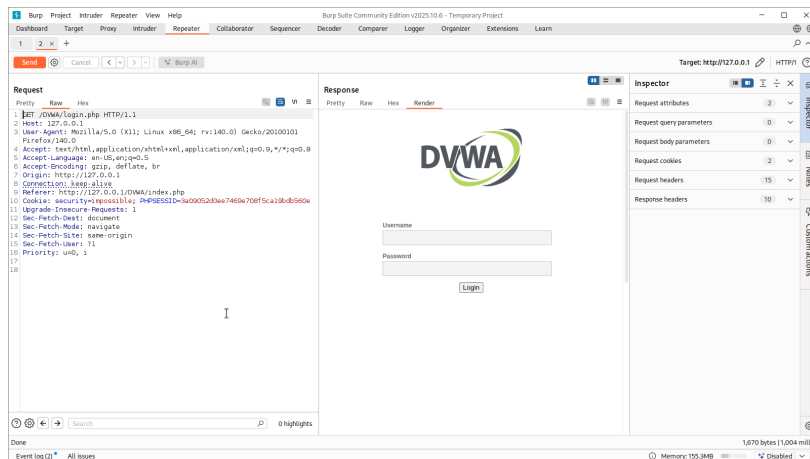


Рисунок 3.24: Как выглядит полученная страница в Render

4 Выводы

При выполнении данной работы я научилась использовать инструмент Vigr Suite.

Список литературы